AEGIS BANK

Customer Privacy Policy

Enterprise AI Decision & Knowledge Platform for Modern Banking

---

Document Information

Field	Details
Document Title	Customer Privacy Policy
Document ID	**AB-COMP-002**
Department	Compliance & Data Protection
Version	v1.2
Last Updated	July 24, 2026
Document Owner	Data Protection Officer (DPO)
Classification	Confidential
Review Date	July 24, 2027
Approved By	**Sami Khan – Chief Executive Officer (CEO)**

Confidentiality Notice

This Customer Privacy Policy defines how Aegis Bank collects, processes, protects, and manages customer information throughout the customer relationship lifecycle.

The policy ensures customer information is handled securely, transparently, and in compliance with applicable banking regulations and privacy requirements.

Unauthorized access, disclosure, or misuse of customer information is strictly prohibited.

Table of Contents

1. Purpose

2. Scope
3. Customer Privacy Principles
4. Types of Customer Information Collected
5. Customer Data Collection Process
6. Customer Consent Management
7. Customer Data Usage
8. Customer Data Protection Controls
9. Employee Access Management
10. Customer Data Sharing
11. Customer Rights
12. Data Retention Requirements
13. Privacy Incident Management
14. AI & Customer Data Protection
15. Practical Examples
16. FAQs
17. Revision History
18. Document Approval

---

1. Purpose

The purpose of this policy is to establish requirements for protecting customer information and maintaining customer trust.

This policy ensures:

- Secure handling of customer data.
- Transparent information processing.
- Compliance with privacy regulations.
- Prevention of unauthorized access.

- Protection against fraud and misuse.

---

2. Scope

This policy applies to:

- Retail banking customers.
- Corporate customers.
- Loan customers.
- Credit card customers.
- Digital banking users.
- Customer service operations.
- Employees handling customer information.
- Third-party service providers.

It covers customer information stored in:

- Core Banking Systems.
- Mobile banking applications.
- Internet banking platforms.
- CRM systems.
- Loan processing systems.
- AI-powered banking tools.

---

3. Customer Privacy Principles

Aegis Bank follows these privacy principles:

Transparency

Customers must understand:

- What information is collected.

- Why it is collected.
- How it is protected.
- How it is used.

Data Minimization

Only required customer information shall be collected.

Security Protection

Customer data must be protected using appropriate technical and organizational controls.

Purpose Limitation

Customer information shall only be used for approved banking purposes.

Accountability

The Bank maintains documentation and controls to demonstrate privacy compliance.

---

4. Types of Customer Information Collected

Aegis Bank may collect:

Personal Information

Examples:

- Full name.
- Date of birth.
- Address.
- Phone number.
- Email address.
- National identification details.

Financial Information

Examples:

- Account details.
- Transaction history.
- Loan information.
- Payment records.
- Credit information.

Authentication Information

Examples:

- Login identifiers.
- Security verification information.
- Authentication records.

Digital Information

Examples:

- Device information.
- Login activity.
- Application usage data.
- Security logs.

---

5. Customer Data Collection Process

Customer information may be collected through:

- Account opening.
- KYC verification.

- Loan applications.
- Customer support interactions.
- Digital banking services.
- Fraud prevention systems.

Before collecting information, Aegis Bank ensures:

- Legal purpose exists.
- Customer is informed.
- Data requirements are documented.

---

6. Customer Consent Management

Where customer consent is required, Aegis Bank ensures:

- Consent is clearly requested.
- Purpose is explained.
- Consent records are maintained.
- Customers may withdraw consent where applicable.

Examples:

- Marketing communications.
- Optional financial services.
- Personalized recommendations.

---

7. Customer Data Usage

Customer information may be used for:

Banking Services

Examples:

- Account management.
- Payments.

- Transfers.
- Loan processing.

Security & Fraud Prevention

Examples:

- Fraud detection.
- Suspicious activity monitoring.
- Account protection.

Regulatory Compliance

Examples:

- KYC requirements.
- Anti-money laundering checks.
- Legal reporting.

Customer Support

Examples:

- Resolving complaints.
- Verifying customer identity.
- Providing assistance.

---

8. Customer Data Protection Controls

Aegis Bank protects customer information through:

- Encryption.
- Multi-Factor Authentication.
- Role-Based Access Control.

- Security monitoring.
- Audit logs.
- Data classification.
- Secure backups.
- Network protection.

Customer financial information is treated as **Confidential** or **Restricted** depending on sensitivity.

---

9. Employee Access Management

Employees may access customer information only when required for their job responsibilities.

Access is controlled through:

- User authentication.
- Role-based permissions.
- Approval processes.
- Activity monitoring.

Employees are prohibited from:

- Browsing customer accounts without business need.
- Sharing customer records.
- Copying customer information unnecessarily.

---

10. Customer Data Sharing

Customer information may only be shared with:

- Authorized employees.
- Approved service providers.
- Regulatory authorities.
- Legal entities where required.

Before sharing:

- Business purpose must be verified.
- Security requirements must be reviewed.
- Appropriate agreements must exist.

---

11. Customer Rights

Customers have the right to:

- Access their personal information.
- Request correction of inaccurate data.
- Understand data usage.
- Request deletion where legally applicable.
- Restrict certain processing activities.
- Raise privacy concerns.

---

12. Data Retention Requirements

Customer information is retained according to:

- Regulatory requirements.
- Legal obligations.
- Business requirements.
- Security policies.

When retention periods expire:

- Data is securely deleted.
- Records may be anonymized.
- Disposal activities are documented.

---

13. Privacy Incident Management

Any customer data incident must be handled according to:

AB-SEC-004 — Cyber Security Incident Response Plan

Examples:

- Unauthorized account access.
- Customer information exposure.
- Lost documents.
- Incorrect data sharing.

Response includes:

1. Detection.
2. Containment.
3. Investigation.
4. Risk assessment.
5. Corrective actions.

---

14. AI & Customer Data Protection

Aegis Bank AI systems, including **Aegis AI OS**, must protect customer information.

AI systems must:

- Follow access permissions.
- Prevent unauthorized customer data retrieval.
- Maintain activity logs.
- Use approved data sources.
- Support privacy compliance.

Customer information must not be exposed to unauthorized AI models or external systems.

---

15. Practical Examples

Example 1 — Customer Account Inquiry

A customer contacts support regarding an account issue.

Process:

- Verify customer identity.
- Access only required information.
- Resolve request.
- Record interaction.

Example 2 — Employee Access Attempt

An employee tries to view a customer's account without a business reason.

Result:

- Access is denied.
- Activity is logged.
- Security review may be initiated.

Example 3 — Fraud Detection

AI system identifies unusual transaction behavior.

Process:

- Analyze transaction patterns.
- Protect customer account.
- Alert security team.

Example 4 — Customer Data Export Request

Customer requests personal information.

Process:

- Verify identity.
- Prepare approved data report.
- Deliver securely.

16. Customer Privacy Training

Aegis Bank ensures that employees handling customer information receive regular privacy training.

Training covers:

- Customer confidentiality requirements.
- Secure handling of financial information.
- GDPR privacy principles.
- Data access responsibilities.
- Fraud prevention awareness.
- Reporting privacy incidents.
- Secure communication practices.

Training Requirements

Employees must complete:

- Privacy training during onboarding.
- Annual privacy awareness training.
- Additional training after major policy updates.
- Role-specific training for sensitive departments.

Departments requiring enhanced training:

- Customer Support.
- Compliance.
- Information Security.
- Loan Operations.
- Fraud Management.
- IT Administration.

---

17. Data Privacy Governance

Aegis Bank maintains a privacy governance framework to ensure responsible customer data management.

Privacy governance includes:

- Privacy policies.
- Data protection standards.
- Compliance monitoring.
- Risk assessments.
- Internal reviews.
- Employee awareness programs.

Privacy Governance Structure

Role	Responsibility
Chief Executive Officer (CEO)	Executive oversight
Data Protection Officer (DPO)	Privacy compliance management
Compliance Department	Regulatory monitoring
Information Security	Technical protection
Department Managers	Operational compliance
Employees	Responsible data handling

---

18. Third-Party Customer Data Handling

Third-party providers that process customer information must follow Aegis Bank privacy requirements.

Examples:

- Payment processors.
- Cloud service providers.

- Identity verification providers.
- Customer support platforms.

Third-Party Requirements

Before granting access:

- Vendor privacy assessment.
- Security evaluation.
- Data processing agreement.
- Access limitation.
- Compliance review.

Third parties must:

- Protect customer information.
- Use data only for approved purposes.
- Maintain confidentiality.
- Report privacy incidents.
- Delete data after contract completion.

---

19. Customer Privacy Complaint Process

Customers may raise privacy concerns through approved communication channels.

Examples:

- Unauthorized data usage.
- Incorrect personal information.
- Privacy concerns.
- Data access requests.

Complaint Handling Process

Step 1 — Receive Complaint

Customer complaint is recorded with:

- Customer details.
- Complaint category.
- Date received.
- Description.

Step 2 — Verification

The Bank verifies:

- Customer identity.
- Request validity.
- Relevant information.

Step 3 — Investigation

Responsible teams review:

- Data processing activity.
- Access records.
- System logs.
- Employee actions.

Step 4 — Resolution

The Bank provides:

- Explanation.
- Correction.
- Remediation.
- Required actions.

---

20. Privacy Monitoring & Auditing

Aegis Bank continuously monitors privacy compliance.

Monitoring activities include:

- Access reviews.
- Data usage monitoring.
- Privacy control testing.
- Employee compliance checks.
- Third-party reviews.

Audit Areas

Audits may review:

- Customer data access.
- Data retention practices.
- Security controls.
- Privacy requests.
- Vendor compliance.

Audit findings must be documented and tracked until completion.

---

21. Customer Data Protection During Digital Banking

Digital banking services must maintain strong privacy controls.

Controls include:

- Secure login.
- Multi-Factor Authentication.
- Encryption.
- Session monitoring.

- Fraud detection.
- Secure communication.

Mobile Banking Protection

Mobile applications must:

- Protect stored information.
- Validate user identity.
- Prevent unauthorized access.
- Receive security updates.
- Monitor suspicious activity.

---

22. Customer Data in Artificial Intelligence Systems

Aegis Bank uses AI technologies responsibly while protecting customer privacy.

AI systems must:

- Use approved datasets.
- Follow access permissions.
- Avoid unnecessary personal data processing.
- Maintain transparency.
- Support audit requirements.

AI Customer Data Example

Customer asks:

"Why was my transaction flagged?"

AI system must:

1. Verify customer identity.
2. Retrieve authorized information.

3. Provide approved explanation.
4. Record interaction.

The AI system must not expose:

- Other customer information.
- Internal security rules.
- Restricted banking data.

---

23. Practical Banking Scenarios

Scenario 1 — Unauthorized Employee Access

An employee views customer account information without a business reason.

Response:

- Access activity reviewed.
- Employee action investigated.
- Access permissions evaluated.
- Corrective action applied.

Scenario 2 — Customer Requests Information

A customer requests details about stored personal data.

Process:

1. Verify identity.
2. Collect relevant records.
3. Review legal requirements.
4. Provide secure response.

Scenario 3 — Customer Data Sent Incorrectly

An employee accidentally sends a customer document to the wrong recipient.

Response:

- Incident reported immediately.
- Document access restricted.
- Risk assessment performed.
- Privacy team determines next actions.

Scenario 4 — AI Assistant Request

Employee asks Aegis AI OS:

"Show customer transaction details."

Response:

AI checks:

- User identity.
- Employee role.
- Permission level.

If unauthorized:

➡️ Access denied.

---

24. Frequently Asked Questions (FAQs)

Q1. Why does Aegis Bank collect customer information?

Customer information is collected to provide banking services, meet regulatory obligations, prevent fraud, and improve customer support.

Q2. Who can access customer information?

Only authorized employees with a legitimate business requirement can access customer information.

Q3. Can employees share customer information through email?

Only through approved secure communication methods. Personal email accounts must not be used.

Q4. How does Aegis Bank protect customer data?

Through encryption, access controls, MFA, monitoring, security policies, and compliance procedures.

Q5. Does AI have access to all customer information?

No. AI systems only access approved information based on user permissions and security controls.

Q6. What happens if customer information is exposed?

The Bank activates its incident response process, investigates the issue, and applies corrective actions.

---

25. Related Documents

This policy should be read together with:

- GDPR & Privacy Policy (AB-COMP-001)
- Risk Management Framework (AB-COMP-003)
- Internal Audit Manual (AB-COMP-004)
- Regulatory Compliance Manual (AB-COMP-005)
- Data Classification Policy (AB-SEC-005)
- Cyber Security Policy (AB-SEC-003)
- AI Usage Policy (AB-AI-001)

---

26. Revision History

Version	Date	Description	Author
v1.0	February 15, 2026	Initial Customer Privacy Framework Release	Compliance & Data Protection
v1.1	May 20, 2026	Added AI Privacy Controls and Customer Data Monitoring	Data Protection Officer
v1.2	**July 24, 2026**	**Enhanced Customer Rights, Digital Banking Privacy, and AI Data Protection Requirements**	**Compliance & Data Protection Department**

---

27. Document Approval

Field	Details
Document ID	**AB-COMP-002**
Document Title	**Customer Privacy Policy**
Department	Compliance & Data Protection
Version	**v1.2**
Classification	**Confidential**
Document Owner	Data Protection Officer (DPO)
Approved By	**Sami Khan – Chief Executive Officer (CEO)**
Approval Date	**July 24, 2026**
Next Review Date	**July 24, 2027**

Document Control

Attribute	Value
Document Status	Approved

Attribute	Value
Distribution	Compliance, Customer Operations, Information Security, IT, Risk Management
Language	English
Storage Location	Aegis Bank Document Management System (DMS)
Retention Period	7 Years
Supersedes	Customer Privacy Policy v1.1

End of Document

Aegis Bank
Enterprise AI Decision & Knowledge Platform for Modern Banking

© 2026 Aegis Bank. All Rights Reserved.